

CloudGuardian

Week 3 - Remediate and Govern

IIT Roorkee - PG Certificate in AI Powered Cybersecurity
Capstone Project - Microsoft Azure Track

Kedar Pavaskar

Where We Left Off

Two weeks of foundation this week's automation depends on

1

Build & Break

3-tier Azure workload via Terraform, 16 deliberate misconfigurations across IAM, storage, networking, encryption, logging.

2

Detect & Prioritize

3 CSPM tools cross-referenced into one findings schema; CVSS x Exposure x Blast-Radius risk scoring; LLM explanations verified against raw scanner data.

3

Remediate & Govern

Today: safe automated fixes, human approval gate, continuous drift detection, privacy-preserving LLM calls, full compliance crosswalk.

Week 3 Objectives

1

Automate safely

Fix 6 well-understood, reversible controls without a human touching a keyboard - for low-risk findings only.

2

Gate on approval

High/Critical findings require an explicit human Approve before anything changes.

3

Govern, not just fix

Re-verify daily that a remediated control hasn't silently drifted back.

4

Protect privacy in the loop

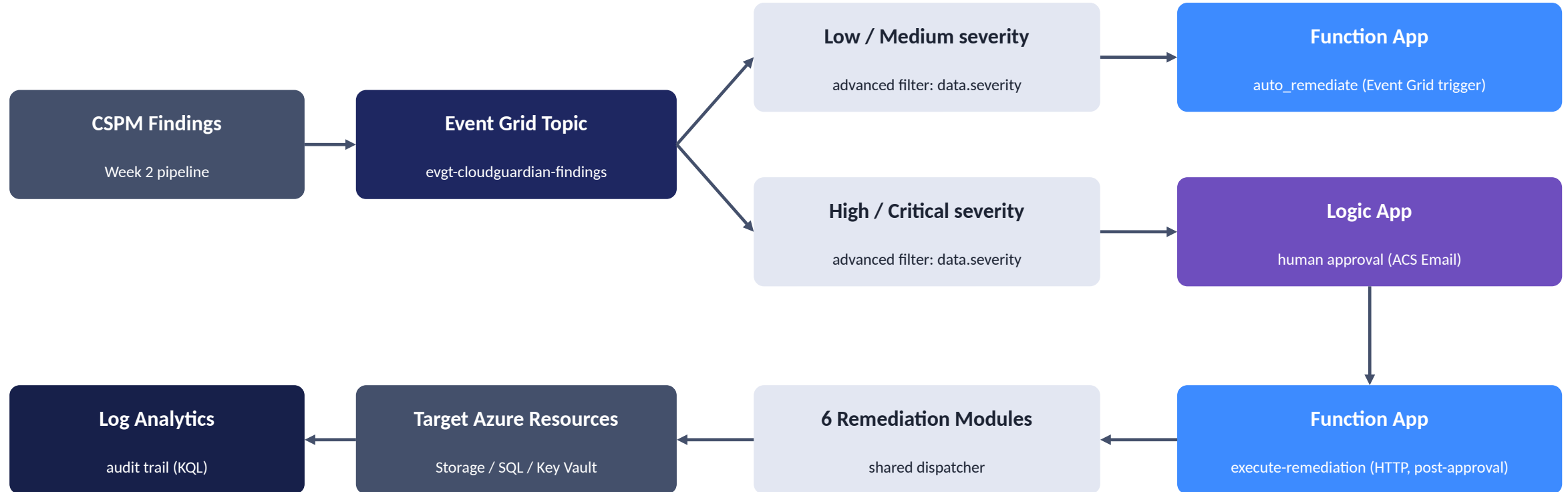
Tokenize identifying data before any LLM call; hard-block the call if anything leaks.

5

Prove compliance

Map every control to ISO 27001 Annex A, Microsoft Cloud Security Benchmark, and DPDP Act 2023.

Event-Driven Remediation Architecture



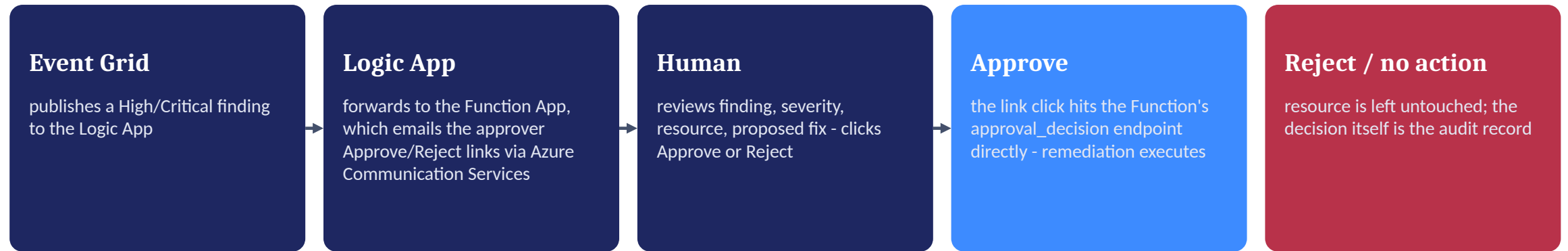
Automation Account (daily): re-checks all 6 controls, flags drift without silently re-fixing

Six Safe, Idempotent, Reversible Fixes

Control	Fix	CIS / MCSB
storage_public_access	Disable account-level anonymous blob access	CIS 3.6 / MCSB DP-2, NS-2
storage_encryption	Enforce HTTPS-only + TLS 1.2 minimum	CIS 3.1, 3.12 / MCSB DP-3, DP-4
diagnostic_logging	Re-attach diagnostics to Log Analytics	CIS 5.1.x / MCSB LT-3, LT-4
sql_encryption	Enable Transparent Data Encryption	CIS 4.1.1 / MCSB DP-4
keyvault_firewall	Network ACL default action -> Deny	MCSB NS-2, DP-8
tagging	Merge required governance tags	MCSB GS-1

All 6 are boolean/property toggles - no destructive operations, all idempotent, all reversible.

The Human Approval Gate



Approving does not just log a decision - it is the ONLY thing that authorizes the Function to make a live change.

Governance: Remediation Isn't a One-Time Fix

Daily

Automation Account runbook re-checks all 6 controls

Test-RemediationDrift.ps1 runs as the Automation Account's own Managed Identity - same read-only calls an auditor would make.

Flags drift. Does NOT silently re-fix it.

Drift is a signal a human should look at - was it accidental, or a deliberate, approved exception?

- Storage public access
- Storage HTTPS/TLS
- Diagnostic logging
- SQL TDE
- Key Vault firewall
- Required tags

Privacy-Preserving LLM Pipeline



DPDP Rules, 2025: reasonable security safeguards include “encryption, obfuscation, masking, or the use of virtual tokens mapped to specific personal data.” This pipeline implements that safeguard literally, for UPNs and tenant identifiers.

Compliance Crosswalk at a Glance

10

controls mapped
end to end

12+

ISO/IEC 27001:2022
Annex A references

1

Microsoft Cloud Security
Benchmark (v1, GA)

2025

DPDP Rules notified
(14 Nov 2025)

Full row-by-row mapping: [Week3_Compliance_Crosswalk.xlsx](#)

DPDP Act 2023 status - stated accurately, not oversold

Rules notified 14 Nov 2025. Data Protection Board instituted immediately. Consent Manager registration from Nov 2026. **Main compliance duties - security safeguards, breach notification - become mandatory 13 May 2027.**

CloudGuardian's privacy pipeline is built ahead of the mandatory date, not because it is currently required.

Security Design Decisions

Zero Trust

System-Assigned Managed Identity only - no stored secret, no service principal password anywhere in this stack.

Least privilege

A custom RBAC role scoped to exactly the actions 6 remediations need - not built-in Contributor.

Defense in depth

Key Vault firewall changes are approval-gated even at low severity - the one control that could break a legitimate caller.

Auditable by default

Every remediation, approval, and drift check is independently logged and queryable via KQL.

Live Demo - What You're About to See

1

Toggle a real misconfiguration by hand (Storage public access)

2

Publish the finding to Event Grid (curl - simulates Week 2's pipeline)

3

Medium severity -> auto-remediates in seconds, no human involved

4

High severity (SQL encryption) -> approval email arrives -> Approve -> Function executes

5

Query Log Analytics live: one KQL query shows both remediations in the audit trail

Challenges & Lessons Learned

An M365 mailbox would have blocked the lab

The original approval design used the Office 365 Outlook connector's Send-email action, which needs a real Microsoft 365 mailbox and a manual OAuth click. Redesigned around Azure Communication Services Email (Managed Identity auth) with the Function App handling the Approve/Reject branch - removed the M365 dependency AND the azapi provider it also required, simplifying the stack as a side effect.

Azure SDK vs. Portal terminology drift

TDE is an attribute on the database, not a separate resource - consistent with what Week 1 already taught about `azurerm_mssql_database_transparent_data_encryption` not existing.

A privacy bug caught by testing, not review

An early tokenizer regex missed hyphen-less storage account names in free text - fixed by tokenizing known structured values as exact literals first, regex only as a last-resort net.

Windows tooling friction (Week 1 carryover)

Prowler's MAX_PATH limit, PowerShell COM [ref] marshalling - same discipline of diagnose-and-fix-sequentially applied again this week.

Results & What's Next

Delivered this week

- 6 remediation functions, idempotent & dry-run capable
- Event-driven routing by severity (Event Grid)
- Human approval gate (Logic App + ACS Email)
- Daily drift-detection governance runbook
- Privacy-preserving, leakage-guarded LLM pipeline
- Full ISO 27001 / MCSB / DPDP crosswalk

Next

- Wire the existing Streamlit dashboard to live Function/Logic App status
- Extend the drift runbook to open a tracked ticket automatically
- Grow from 6 to the full misconfiguration catalogue
- Move Key Vault access from function keys to Azure AD Easy Auth

Thank you

Questions?